

ISO 27001:2022 Annex A Controls

ISO 27001 is the international standard for information security, requiring organizations to identify information security risks and select appropriate controls. Annex A of ISO 27001:2022 contains a list of 93 security controls, grouped into 4 themes:

1. Organisational (37 controls)

Focus on policies, procedures, responsibilities, and other organizational-level measures for effective information security. Examples include:

- * Information security policy and other core policies
- * Defined responsibilities for management and ISMS operations
- * Contact with authorities and relevant groups
- * Threat intelligence and monitoring
- * Classifying and labelling information
- * Identity and access control
- * Asset management

2. People (8 controls)

Focus on human aspects of information security, particularly employees. Examples include:

- * Pre-employment screening
- * Staff awareness and training
- * Contracts and NDAs
- * Remote working
- * Reporting security events

3. Physical (14 controls)

Focus on the physical environment of the ISMS. Examples include:

- * Security perimeters and secure areas
- * Clear desks and screens
- * Supporting utilities
- * Secure cabling
- * Equipment maintenance

4. Technological (34 controls)

Focus on technology-related aspects of information security. Examples include:

- * Malware protection
- * Backups
- * Logging and monitoring
- * Network security and segregation
- * Development and coding practices

Statement of Applicability (SoA)

The SoA is a crucial document in an ISMS that lists all Annex A controls, along with justifications for their inclusion or exclusion, and their implementation status. It also includes any controls from other frameworks or additional controls developed by the organization. The SoA is a key focus during certification and surveillance audits.